基本情報技術者試験　テクノロジ系　No.11

セキュリティ

情報セキュリティ・情報セキュリティ管理・セキュリティ技術評価・情報セキュリティ対策・セキュリティ実装技術

目次

1. 11-1 情報セキュリティ（25語）
2. 11-2 情報セキュリティ管理（9語）
3. 11-3 セキュリティ技術評価（3語）
4. 11-4 情報セキュリティ対策（14語）
5. 11-5 セキュリティ実装技術（15語）
6. まとめ

11-1 情報セキュリティ まとめ表

情報セキュリティの3要素（CIA）		
要素	**意味**	**損なわれる例**
機密性	許された人だけが見られる	情報漏えい
完全性	正しく、改ざんされていない	改ざん
可用性	必要なときに使える	DoS攻撃でサービス停止

暗号方式の比べ方		
	共通鍵暗号	**公開鍵暗号**
鍵	暗号化と復号に同じ鍵	公開鍵と秘密鍵のペア
速さ	速い	遅い
鍵の数（n人）	n(n−1)/2 個	2n 個
例	AES	RSA、楕円曲線暗号

11-1 情報セキュリティ 基本の考え方・攻撃の手口

情報セキュリティの3要素
CIA

機密性・完全性・可用性の3つ

ポイント JIS Q 27000では、これに真正性・責任追跡性・否認防止・信頼性を加えることもある

Confidentiality=機密性／Integrity=完全性／Availability=可用性

脅威
きょうい / Threat

情報資産に損害を与えるおそれのあるもの

ポイント 物理的脅威・技術的脅威・人的脅威に分かれる

脆弱性
ぜいじゃくせい / Vulnerability

脅威に付け込まれる弱点

ポイント ソフトウェアの不具合（セキュリティホール）や管理の甘さ

マルウェア
Malware

悪意のあるソフトウェアの総称

ポイント ウイルス・ワーム・トロイの木馬・スパイウェア・ランサムウェアなど

ワーム
Worm

自分を複製し、ネットワークを通じて広がるマルウェア

ポイント ウイルスと違い、宿主のファイルを必要としない

トロイの木馬
Trojan Horse

役に立つソフトを装って入り込み、裏で悪い動きをするマルウェア

11-1 情報セキュリティ 攻撃の手口

ランサムウェア
Ransomware

データを暗号化するなどして使えなくし、元に戻すための身代金を要求するマルウェア

ポイント オフラインのバックアップが有効な対策

ボット
Bot

外部のC&Cサーバからの指令で遠隔操作されるマルウェア

ポイント 感染した端末の集まりをボットネットという

ソーシャルエンジニアリング
Social Engineering

人の心理的な隙や油断を突いて、パスワードなどの情報を盗む手口

例 電話でなりすまして聞き出す、肩越しに盗み見る

フィッシング
Phishing

本物そっくりの偽サイトに誘導し、IDやパスワードを入力させて盗む手口

標的型攻撃
ひょうてきがたこうげき / Targeted Attack

特定の組織を狙い、業務を装ったメールなどでマルウェアに感染させる攻撃

水飲み場型攻撃
Watering Hole Attack

標的がよく見るWebサイトを改ざんし、訪れた人を感染させる攻撃

11-1 情報セキュリティ 攻撃の手口

ゼロデイ攻撃
Zero-day Attack

脆弱性が見つかってから修正プログラムが出るまでの間に、その脆弱性を突く攻撃

ブルートフォース攻撃
総当たり攻撃 / Brute Force Attack

パスワードとして考えられるすべての組合せを試す攻撃

ポイント 辞書攻撃はよく使われる単語を順に試す

パスワードリスト攻撃
Password List Attack

ほかのサービスから漏れたIDとパスワードの組を使ってログインを試す攻撃

ポイント パスワードの使い回しが原因になる

リバースブルートフォース攻撃
Reverse Brute Force Attack

パスワードを1つに固定し、IDを次々に変えて試す攻撃

ポイント 一定回数の失敗でロックする対策が効きにくい

SQLインジェクション
SQL Injection

入力欄に不正なSQLの一部を入れて、データベースを不正に操作する攻撃

ポイント 対策はプレースホルダ（バインド機構）でSQL文と値を分けること

クロスサイトスクリプティング
XSS / Cross Site Scripting

Webページに悪意のあるスクリプトを埋め込み、閲覧者のブラウザで実行させる攻撃

ポイント 対策は出力時のエスケープ処理

11-1 情報セキュリティ 攻撃の手口

CSRF
しーさーふ / Cross Site Request Forgery

ログイン中の利用者に、意図しない操作の要求を送らせる攻撃

ポイント 対策は正規の画面から送られたか確かめるトークン

Cross Site＝サイトをまたいだ／Request＝要求／Forgery＝偽造

DoS攻撃・DDoS攻撃
ドスこうげき / Denial of Service

大量の通信を送りつけて、サービスを使えなくする攻撃。多数の端末から行うのがDDoS

Denial of Service＝サービスの妨害／Distributed＝分散した（DDoS）

DNSキャッシュポイズニング
DNS Cache Poisoning

DNSサーバに偽の情報を覚えさせ、正しいドメイン名でも偽サイトへ誘導する攻撃

中間者攻撃
MITM / Man-in-the-Middle Attack

通信の間に入り込んで、盗聴や改ざんをする攻撃

敵対的サンプル
Adversarial Example

画像などに人には分からない小さな変化を加え、AIに誤認識させる攻撃

モデル反転攻撃
Model Inversion Attack

AIの出力をもとに、学習に使ったデータ（個人情報など）を推測する攻撃

11-1 情報セキュリティ 攻撃の手口

適応的選択平文攻撃
Adaptive Chosen-plaintext Attack

攻撃者が選んだ平文と暗号文の組を、結果を見ながら次々に入手して鍵を推測する暗号解読の手法

11-2 情報セキュリティ管理 組織での管理

ISMS
あいえすえむえす / Information Security Management System

情報セキュリティを組織として管理し、PDCAで継続的に改善する仕組み

ポイント 規格は JIS Q 27001（ISO/IEC 27001）

Information Security＝情報セキュリティ／Management System＝管理の仕組み

情報セキュリティポリシー
Information Security Policy

組織の情報セキュリティの方針や決まりをまとめたもの

ポイント 基本方針・対策基準・実施手順の3階層

リスクアセスメント
Risk Assessment

リスクを特定し、分析し、評価すること

リスク対応
Risk Treatment

評価したリスクにどう対処するかを決めること

ポイント 回避（やめる）・低減（対策で小さくする）・移転（保険などで他者へ）・保有（受け入れる）

リスク移転
Risk Transfer

保険に入るなどして、損失の負担を第三者に移すこと

リスク保有
Risk Retention

リスクを受け入れ、損失が出たら自分で負担すること

ポイント 小さなリスクに選ぶ

11-2 情報セキュリティ管理 組織での管理

CSIRT
しーさーと / Computer Security Incident Response Team

セキュリティ事故（インシデント）が起きたときに、分析・対応・再発防止を担う組織

Computer Security＝コンピュータセキュリティ／Incident＝事故／Response＝対応／Team＝チーム

個人情報保護
Personal Information Protection

個人情報を適切に扱うこと

ポイント プライバシーマーク制度は、適切に扱う事業者を認定する

SOC
そっく / Security Operation Center

ネットワークや機器を24時間監視し、攻撃を見つけて分析する組織

Security＝セキュリティ／Operation＝運用／Center＝拠点

11-3 セキュリティ技術評価 評価と検査

ペネトレーションテスト
Penetration Test

実際の攻撃と同じ手順でシステムに侵入を試み、弱点を確かめる検査

ファジング
Fuzzing

予想外のデータを大量に入力して、ソフトウェアの脆弱性を見つける検査

CVSS
しーぶいえすえす / Common Vulnerability Scoring System

脆弱性の深刻さを、0〜10の点数で表す共通の評価方法

Common＝共通の／Vulnerability＝脆弱性／Scoring System＝点数の付け方

11-4 情報セキュリティ対策 人と物の対策

多要素認証
たようそにんしょう / Multi-factor Authentication

知識（パスワード）・所持（スマートフォン）・生体（指紋）のうち、2種類以上を組み合わせる認証

ポイント 同じ種類を2回使うのは二段階認証であっても多要素ではない

ワンタイムパスワード
One-time Password

1回使うと無効になるパスワード

ポイント 盗まれても再利用されにくい

生体認証
せいたいにんしょう / Biometrics

指紋・顔・静脈など、体の特徴で本人を確認する方法

ポイント 本人を拒否する率と、他人を受け入れる率のバランスが大切

シングルサインオン
SSO / Single Sign-On

一度の認証で、複数のシステムを使えるようにする仕組み

セキュアブート
Secure Boot

起動時に電子署名を確かめ、信頼できるOSだけを起動させる仕組み

BIOSパスワード・HDDパスワード
BIOS / HDD Password

BIOSパスワードはPCの起動や設定の変更を制限し、HDDパスワードは記憶装置そのものの読み出しを制限する

11-4 情報セキュリティ対策 技術的な対策

ファイアウォール
Firewall

決めたルールに従って、通信を通すか止めるかを判断する仕組み

ポイント パケットフィルタリングはIPアドレスやポート番号で判断する

DMZ
でぃーえむぜっと / DeMilitarized Zone

社内ネットワークとインターネットの間に置く、外部に公開するサーバ用の区域

ポイント Webサーバやメールサーバを置く

DeMilitarized=非武装の／Zone=地帯

WAF
わふ / Web Application Firewall

Webアプリケーションへの攻撃（SQLインジェクションやXSSなど）を見つけて防ぐ仕組み

Web Application=Webアプリ／Firewall=防火壁

IDS
あいでぃーえす / Intrusion Detection System

不正な侵入を見つけて知らせる仕組み

ポイント 止めるところまで行うのがIPS（Intrusion Prevention System）

Intrusion=侵入／Detection=検知／System=仕組み

マルウェア対策ソフト
Anti-malware Software

マルウェアを見つけて取り除くソフト

ポイント パターンマッチング法は定義ファイルと照合、ヒューリスティック法は怪しい振る舞いから検出、コンペア法は正常な状態と比べる

11-4 情報セキュリティ対策 技術的な対策

サンドボックス
Sandbox

隔離した環境で怪しいプログラムを動かし、振る舞いを観察する仕組み

バックアップ
Backup

データの複製を別の場所に保存しておくこと

ポイント ランサムウェア対策ではネットワークから切り離した保管が有効

WORM
わーむ / Write Once Read Many

一度だけ書き込め、何度でも読める記録媒体や機能

ポイント ログなどの改ざん防止に使う

Write Once＝一度だけ書く／Read Many＝何度も読む

11-5 セキュリティ実装技術 暗号と認証の技術

共通鍵暗号方式
きょうつうかぎあんごうほうしき / Symmetric-key Cryptography

暗号化と復号に同じ鍵を使う方式

ポイント 速いが、鍵を安全に渡す方法が課題。代表はAES

公開鍵暗号方式
こうかいかぎあんごうほうしき / Public-key Cryptography

公開鍵と秘密鍵のペアを使う方式

ポイント 受信者の公開鍵で暗号化し、受信者の秘密鍵で復号する。代表はRSA

AES
えーいーえす / Advanced Encryption Standard

米国の標準になっている共通鍵暗号

Advanced=高度な／Encryption=暗号化／Standard=標準

RSA
あーるえすえー / Rivest-Shamir-Adleman

大きな数の素因数分解が難しいことを安全性の根拠にする公開鍵暗号

考案した3人（Rivest・Shamir・Adleman）の頭文字

楕円曲線暗号
だえんきょくせんあんごう / Elliptic Curve Cryptography

楕円曲線の性質を使う公開鍵暗号

ポイント RSAより短い鍵で同じくらいの強さを出せる

ハッシュ関数
Hash Function

データから決まった長さの値（ハッシュ値）を作る関数

ポイント 元に戻せず、少しでも違うと値が変わるので改ざんの検出に使う。例: SHA-256

11-5 セキュリティ実装技術 暗号と認証の技術

ディジタル署名
Digital Signature

送信者が自分の秘密鍵で署名し、受信者が送信者の公開鍵で検証する仕組み

ポイント 本人であることと、改ざんされていないことを確かめられる

PKI
ぴーけーあい / Public Key Infrastructure

認証局（CA）が発行するディジタル証明書で、公開鍵が本人のものだと保証する仕組み

Public Key＝公開鍵／Infrastructure＝基盤

TLS
てぃーえるえす / Transport Layer Security

Webなどの通信を暗号化し、相手を認証するプロトコル

ポイント 前身はSSL。HTTPSで使う

Transport Layer＝トランスポート層の／Security＝安全

IPsec
あいぴーせっく / IP Security

ネットワーク層でIP通信を暗号化・認証するプロトコル群

ポイント VPNで使われる

VPN
ぶいぴーえぬ / Virtual Private Network

共用の回線の上に、暗号化で仮想的な専用線を作る技術

Virtual＝仮想の／Private＝専用の／Network＝網

11-5 セキュリティ実装技術 暗号と認証の技術

WPA
だぶりゅーぴーえー / Wi-Fi Protected Access

無線LANの暗号化と認証の規格

ポイント 今はWPA3が新しい

Wi-Fi＝無線LAN／Protected＝守られた／Access＝接続

DMARC
でぃーまーく / Domain-based Message Authentication, Reporting and Conformance

SPFやDKIMの送信元認証の結果をもとに、なりすましメールをどう扱うかを送信側が示す仕組み

Domain-based＝ドメインに基づく／Message Authentication＝メールの認証／Reporting＝報告／Conformance＝適合

SPF・DKIM
えすぴーえふ・でぃーきむ

送信元のメールサーバが正しいかを確かめる仕組み。SPFは送信元IPアドレス、DKIMは電子署名で確かめる

プロキシサーバ
Proxy Server

社内の端末に代わって外部のサーバに接続する中継サーバ

ポイント アクセスの記録や制限に使う

まとめ この分野で覚える用語

小分類	用語
11-1 情報セキュリティ	情報セキュリティの3要素・脅威・脆弱性・マルウェア・ワーム・トロイの木馬・ランサムウェア・ボット・ソーシャルエンジニアリング・フィッシング・標的型攻撃・水飲み場型攻撃・ゼロデイ攻撃・ブルートフォース攻撃・パスワードリスト攻撃・リバースブルートフォース攻撃・SQLインジェクション・クロスサイトスクリプティング・CSRF・DoS攻撃・DDoS攻撃・DNSキャッシュポイズニング・中間者攻撃・敵対的サンプル・モデル反転攻撃・適応的選択平文攻撃
11-2 情報セキュリティ管理	ISMS・情報セキュリティポリシー・リスクアセスメント・リスク対応・リスク移転・リスク保有・CSIRT・SOC・個人情報保護
11-3 セキュリティ技術評価	ペネトレーションテスト・ファジング・CVSS
11-4 情報セキュリティ対策	多要素認証・ワンタイムパスワード・生体認証・シングルサインオン・セキュアブート・BIOSパスワード・HDDパスワード・ファイアウォール・DMZ・WAF・IDS・マルウェア対策ソフト・サンドボックス・WORM・バックアップ
11-5 セキュリティ実装技術	共通鍵暗号方式・公開鍵暗号方式・AES・RSA・楕円曲線暗号・ハッシュ関数・ディジタル署名・PKI・TLS・IPsec・VPN・WPA・DMARC・SPF・DKIM・プロキシサーバ